



CERTIFICATION STUDY GUIDE

Data Protection Officer Study Guide

A complete study companion for the POTRAZ / HIT Data Protection Officer certification — built from the Cyber and Data Protection Act [Chapter 12:07] and Statutory Instrument 155 of 2024.

Document Study Guide

Standard Cyber & Data Protection Act [Chapter 12:07] · SI 155 of 2024

Prepared with VAKA OS

For the POTRAZ / HIT DPO Certification Course Based on the Cyber and Data Protection Act [Chapter 12:07] (Act 5 of 2021), Statutory Instrument 155 of 2024, and POTRAZ's DPO Implementation Guidelines.

How to use this guide: read Part 1–3 for the law you must know verbatim, Part 4–6 for the DPO role and practice, and Part 7 for exam technique. The numbers, deadlines, forms and penalties in the boxes are the ones most likely to be tested — memorise them exactly.

Part 1 — The legal landscape

1.1 The instruments

There are three documents that govern everything a Zimbabwean DPO does:

1. **Cyber and Data Protection Act [Chapter 12:07]** — the primary statute (Act 5 of 2021). It created data protection law in Zimbabwe, designated the Data Protection Authority, and set the principles and offences.
2. **SI 155 of 2024** — *Cyber and Data Protection (Licensing of Data Controllers and Appointment of Data Protection Officers) Regulations, 2024*. This is the operational rulebook: licensing tiers, fees, forms, timelines, DPO appointment and functions.
3. **POTRAZ Implementation Guidelines on the Appointment, Roles, Responsibilities, Training and Certification of DPOs** — issued under section 20(6) of the Act; repealed Regulatory Notice 1 of 2022.

1.2 Who is POTRAZ?

The **Postal and Telecommunications Regulatory Authority of Zimbabwe (POTRAZ)** is the designated **Data Protection Authority (the "Authority")**. It licenses data controllers, accredits training, certifies DPOs, maintains the public register, investigates breaches and enforces penalties.

Also relevant: the **Cyber Security and Monitoring of Interception of Communications Centre** and the **Cyber Incident Response Team (zw-CIRT)**, which give technical security advice to controllers and processors.

Part 2 — Key definitions (know these cold)

Personal data / personal information — any information relating to an identified or identifiable data subject.

Data subject — the identifiable natural person the data relates to.

Data controller — a person who, alone or jointly, determines the *purposes and means* of processing personal data.

Data processor — a person who processes data on behalf of the controller.

Processing — any operation performed on personal data (collection, recording, storage, use, disclosure, erasure, etc.).

Data Protection Officer (DPO) — the person appointed by a controller to monitor compliance and act as contact point.

Sensitive personal data — data revealing racial/ethnic origin, political opinions, religious/philosophical beliefs, trade union membership, health, sex life, biometric or genetic data, criminal history, etc.

Biometric data — physiological characteristics related to a data subject, including fingerprints, palm veins, and face recognition.

Consent — freely given, specific, informed and unambiguous indication of the data subject's agreement.

Part 3 — The data protection principles

Personal data must be:

1. **Lawful, fair and transparent** — processed on a valid legal basis, fairly, and openly.
2. **Purpose-limited** — collected for specified, explicit and legitimate purposes; not further processed incompatibly.
3. **Minimised** — adequate, relevant and limited to what is necessary.
4. **Accurate** — kept accurate and up to date; inaccurate data erased or corrected.
5. **Storage-limited** — kept no longer than necessary for the purpose.
6. **Secure (integrity & confidentiality)** — protected by appropriate technical and organisational measures.
7. **Accountable** — the controller is responsible for, and must be able to demonstrate, compliance.

Exam tip: expect a question asking you to list the principles and *apply* them to a scenario (e.g. a bank keeping loan records for 40 years fails **storage limitation**; a clinic emailing patient lists unencrypted fails **security**).

3.1 Lawful bases for processing

Processing is lawful where at least one applies: the data subject's **consent**; performance of a **contract**; compliance with a **legal obligation**; protection of **vital interests**; a task in the **public interest**; or the controller's **legitimate interests** (balanced against the data subject's rights). Sensitive data needs a stronger basis (explicit consent or specific legal authorisation).

3.2 Data subject rights

Right to be **informed**; right of **access**; right to **rectification**; right to **erasure**; right to **object**; right to **restrict** processing; right not to be subject to **solely automated decisions** that produce legal effects (without consent or legal basis); and the right to **lodge a complaint** with POTRAZ.

3.3 Children's data (SI 155, s.10(5))

No processing of a child's data without **parent/guardian consent**.

Make reasonable efforts to **verify** that consent.

Apply all processing principles; conduct **regular DPIAs** for children's data.

Build in **data protection by design and by default**.

No automated decision-making that affects a child's rights.

Part 4 — Licensing of data controllers (SI 155, ss.3-9)

4.1 Who must be licensed

Anyone who processes personal data and decides the means, purpose or outcome; decides what data to collect; decides which individuals to collect from; or obtains commercial gain from processing — **must apply for a data controller licence** using **Form DP1**.

4.2 Licence tiers (by number of data subjects)

Tier	Data subjects	Initial/renewal fee
Tier 1	50 – 1,000	USD 50
Tier 2	1,001 – 100,000	USD 300
Tier 3	100,001 – 500,000	USD 500
Tier 4	more than 500,000	USD 2,500

Application fee for Tier 2/3/4: **USD 30**.

Licence is valid **12 months**; renew with Form DP1 **at least 3 months before expiry**.

POTRAZ must decide (approve / request more info / reject with reasons) **within 14 days**.

Existing controllers had **6 months** from promulgation to apply.

4.3 Exemptions (s.8)

No licence needed where processing is for: **personal/family/household affairs; law enforcement**; or **journalistic, historical or archival purposes**. Note: law-enforcement and journalistic/historical/archival controllers must still **register** and comply with the principles.

Part 5 — The Data Protection Officer

5.1 Appointment (SI 155, s.12)

Every data controller **must appoint a DPO** and notify POTRAZ in writing using **Form DP2**.

Appoint within **90 days** of promulgation or of a DPO contract ending.

Notify POTRAZ of any change to the DPO's phone/email/address within **14 days**.

Notify POTRAZ of a DPO's dismissal or resignation within **14 days**.

Penalty for failing to appoint a DPO: fine not exceeding **level 7** or imprisonment up to **2 years**, or both.

(Note this is lower than the level-11 / 7-year penalties elsewhere.)

5.2 Qualifications (SI 155, s.13)

A DPO must have skill, qualification or experience in one of: **data science; data analytics; information security systems; information systems audit; law; audit; or any other relevant qualification** — plus

knowledge of national data protection laws and understanding of the controller's business and processing activities.

Every DPO must complete a **POTRAZ-approved certification course**, and only Authority-**accredited** trainers may provide it.

5.3 Functions (SI 155, s.14) — memorise the list

The DPO's duties are to: - **(a) Monitor compliance** with the Act, regulations and internal policies — including managing internal data protection activities, **raising awareness**, **training staff**, and conducting **internal compliance audits**. - **(b)** Handle requests from POTRAZ and from data subjects. - **(c) Advise employees** on their obligations. - **(d)** Advise on and **monitor DPIAs** (data protection impact assessments). - **(e)** Work with **POTRAZ** on its functions relating to the controller. - **(f)** Act as the **contact point** for data subjects about processing of their data.

5.4 Independence and support

The controller must provide **continuous professional development (CPD) training** to keep the DPO's certification current (s.10(1)), and the certification must be **renewed annually**. The DPO advises and monitors but the **controller remains accountable** — including for the acts of its DPO, processors and agents (s.10(4)).

Part 6 — Security, breaches and transfers

6.1 Security of data (SI 155, s.16)

Process data securely using appropriate **technical and organisational measures**: risk assessments; organisational policies; physical and technical controls across all data phases; ensuring **security, confidentiality, integrity and availability**; ability to **restore** data after an incident; and **testing** the effectiveness of measures. zw-CIRT may advise.

6.2 Breach notification (SI 155, s.17) — heavily tested timelines

Report a breach to **POTRAZ within 24 hours** of becoming aware, using **Form DP3**.

If the breach is likely to be **high risk** to individuals' rights, inform the **affected data subjects within 72 hours**.

Keep a **record of all breaches**; maintain detection, investigation and internal reporting procedures.

Respond to POTRAZ information requests within **14 days**; conclude the investigation and submit a report within **21 days** of notification.

6.3 Notifications to POTRAZ (s.10(2))

Controllers must notify POTRAZ of: all processing activities; modifications to indirectly-collected data; any **cross-border transfer** of data outside Zimbabwe; and any processing of **biometric or genetic** data.

6.4 Automated decisions (s.10(3))

No decision based *solely* on automated processing that produces legal effects — unless the data subject **consents** or a **law** provides for it.

6.5 Codes of conduct (s.15)

Filed with POTRAZ for approval under section 30 of the Act. POTRAZ checks Act-compliance, representation level, purpose statement, covered processing, monitoring methods, and consistency with other law. POTRAZ maintains a register of approved codes.

Part 7 — Offences and penalties (memorise the levels)

Contravention	Penalty
Processing without a data controller licence	Fine up to level 11 and/or up to 7 years imprisonment
Failing to renew a licence on time	Level 11 and/or up to 7 years
Submitting false information on application	Level 11 and/or up to 7 years
Breaching controller obligations (s.10)	Level 11 and/or up to 7 years
Providing certification training without accreditation	Level 11 and/or up to 7 years
Breach of security of data (s.16)	Level 11 and/or up to 7 years
Breach-notification failures (s.17)	Level 11 and/or up to 7 years
Failing to appoint a DPO (s.12)	Level 7 and/or up to 2 years

Exam tip: the odd-one-out is **failure to appoint a DPO = level 7 / 2 years**. Almost everything else is **level 11 / 7 years**. Questions love to test this distinction.

Part 8 — The forms (know what each is for)

Form DP1 — Data Controller Application / Renewal (First Schedule). Captures tier, business type, sensitive data handled, data location, security safeguards, designated DPO, and a sworn declaration.

Form DP2 — DPO Designation / Appointment Notification (Third Schedule). Captures controller details, licence number, DPO name, DPO registration number, contacts and DPO qualifications.

Form DP3 — Breach Notification (Fourth Schedule). Captures breach dates, systems breached, nature/volume of records affected, likely impact, and remedial measures.

Part 9 — Exam technique

The exam is one 4-hour written paper. Expect a mix of definitions, short-answer law, and applied scenarios.

Cite the source. When you state a rule, name the instrument and section (e.g. "SI 155, s.17(1)"). Graders reward precision.

Nail the numbers. 24 hours (breach to POTRAZ), 72 hours (to data subjects), 14 days (POTRAZ licence decision / DPO detail changes), 21 days (breach report), 90 days (DPO appointment), 3 months (renewal lead time), 6 months (existing-controller licensing), 12 months (licence validity), annual DPO recertification.

Learn the four tiers and their fees as a table — they are easy marks.

Practise applying principles to facts. Most scenario questions want you to (1) name the principle/right/section breached, (2) explain why, (3) state the fix, (4) state the penalty exposure.

Structure long answers with headings/lists; state the rule, apply it, conclude.

Quick-reference: the numbers that win marks

Item	Value
Breach report to POTRAZ	24 hours
Notify high-risk breach to data subjects	72 hours
POTRAZ licence decision window	14 days
Notify DPO detail change / departure	14 days
Respond to POTRAZ breach info request	14 days
Conclude breach investigation & report	21 days
Appoint a DPO	within 90 days
Renew licence — lead time before expiry	3 months
Existing controllers to get licensed	6 months
Licence validity	12 months
DPO recertification	annually
DPO training fee (Zim / intl)	USD 1,250 / 1,450
DPO application fee (Zim / intl)	USD 30 / 50
Training accreditation fee	USD 5,000 p.a.